

# RETEST ETHICAL HACKING

Proyecto: DT.Claro.Miniprogram.TuLlave\_Mass | Fecha: 21/05/2026

Target API: <https://urs.qa.vettica.co> | Total hallazgos: 11  
Crítica: 1 | Alta: 0 | Media: 4 | Baja: 6  
Priorización: 11 hallazgos — 1 críticos  
- Priorizar remediación de hallazgos CRITICAL (secretos, inyección, auth rota).  
Extensiones analizadas: .acss, .axml, .js, .json

## Endpoints analizados

| # | Metodo | Path                  | Hallazgos |
|---|--------|-----------------------|-----------|
| 1 | GET    | /card/valid/          | 0         |
| 2 | GET    | /card/getBalance/     | 0         |
| 3 | GET    | /card/getInformation/ | 0         |

| Vulnerabilidad                                         | Riesgo   | CVSS | Estado      | Endpoint                                                                                                                              |
|--------------------------------------------------------|----------|------|-------------|---------------------------------------------------------------------------------------------------------------------------------------|
| Hardcoded Credentials                                  | CRITICAL | 9.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Insecure HTTP Endpoint                                 | MEDIUM   | 6.0  | Persistente | <a href="http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA">http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA</a> |
| Insecure HTTP Endpoint                                 | MEDIUM   | 6.0  | Persistente | <a href="http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA">http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA</a> |
| Sensitive Data in Logs                                 | MEDIUM   | 6.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Falta cabecera Strict-Transport-Security (HSTS)        | MEDIUM   | 6.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Falta X-Content-Type-Options                           | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co/">https://urs.qa.vettica.co/</a>                                                                   |
| Falta Referrer-Policy                                  | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co/">https://urs.qa.vettica.co/</a>                                                                   |
| Validación manual requerida: BOLA/IDOR por objeto      | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Validación manual requerida: BFLA por rol              | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Validación manual requerida: Mass Assignment           | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |
| Validación manual requerida: JWT claims/TTL/revocación | LOW      | 3.0  | Persistente | <a href="https://urs.qa.vettica.co">https://urs.qa.vettica.co</a>                                                                     |

## Detalle tecnico

### 1. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798  
Endpoint: <https://urs.qa.vettica.co>  
Descripcion: Coincidencia de patrón HARDCODED\_CREDENTIALS en main/ui/pages/pseForm/pseForm.js:222.  
Recomendacion: No almacenes contraseñas en código; usa gestores de secretos.

### 2. Insecure HTTP Endpoint (MEDIUM)

Estado: Persistente | CWE: CWE-319  
Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>  
Descripcion: Coincidencia de patrón INSECURE\_HTTP en test/getStatusViewModel.test.js:15.  
Recomendacion: Usa https:// para APIs en producción y fuerza redirección HTTP→HTTPS.

### **3. Insecure HTTP Endpoint (MEDIUM)**

Estado: Persistente | CWE: CWE-319

Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>

Descripción: Coincidencia de patrón INSECURE\_HTTP en test/validCardViewModel.test.js:16.

Recomendación: Usa https:// para APIs en producción y fuerza redirección HTTP→HTTPS.

### **4. Sensitive Data in Logs (MEDIUM)**

Estado: Persistente | CWE: CWE-532

Endpoint: <https://urs.qa.vettica.co>

Descripción: Coincidencia de patrón SENSITIVE\_DATA\_LOGGING en main/ui/pages/rechargeAmount/rechargeAmount.js:194.

Recomendación: No registres contraseñas ni tokens; usa enmascaramiento o niveles de log seguros.

### **5. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)**

Estado: Persistente | CWE: CWE-319

Endpoint: <https://urs.qa.vettica.co>

Descripción: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendación: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

### **6. Falta X-Content-Type-Options (LOW)**

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: La respuesta no incluye X-Content-Type-Options: nosniff.

Recomendación: Agrega X-Content-Type-Options: nosniff en API gateway/backend.

### **7. Falta Referrer-Policy (LOW)**

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: No se encontró cabecera Referrer-Policy en la respuesta del API.

Recomendación: Configura Referrer-Policy estricta (p. ej., no-referrer).

### **8. Validación manual requerida: BOLA/IDOR por objeto (LOW)**

Estado: Persistente | CWE: CWE-639

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Ejecuta pruebas con dos identidades y cruza IDs para detectar acceso indebido a recursos de terceros.

### **9. Validación manual requerida: BFLA por rol (LOW)**

Estado: Persistente | CWE: CWE-285

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Prueba endpoints de privilegio alto con cuentas de menor rol y verifica denegación consistente.

### **10. Validación manual requerida: Mass Assignment (LOW)**

Estado: Persistente | CWE: CWE-915

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Intenta campos no permitidos en payloads (role, status, flags internos) y valida whitelists server-side.

**11. Validación manual requerida: JWT claims/TTL/revocación (LOW)**

Estado: Persistente | CWE: CWE-613

Endpoint: <https://urs.qa.vettica.co>

Descripcion: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendacion: Verifica exp/iat/nbf/aud/iss/jti, rotación de claves y revocación de tokens.